

Sprint 5. Final Project Leonardo Romero

Laboratory: SOC Analyst Shift
Ticket ID: TKT-2026-04340
Subject: Weekend Correlation Review
Student: Leonardo Romero
Date: Saturday, July 18, 2026

DELIVERABLE 1. TRIAGE MATRIX

ALERT ID	HYPOTHESIS	SIGNAL VS. NOISE?	SIEM SEV	OPS SEV	COP
TKT-04102	We observe a possible brute force attack, but it is unconfirmed. We can hypothesize that a user or collaborator lost their credentials and used incorrect ones to log in. 14:25:11 LOCKOUT admin_backup (15 attempts threshold) 14:48:03 LOGIN SUCCESS admin_backup from 10.50.8.45 (post-unlock) Account unlock, configuration reading + hash list download from \srv-backup-01\Backup_Config\ using the admin_backup user. EMAIL ACTIVITY: admin_backup@northbay.internal Fri-Sat window. No sent or received emails detected. Service account has no mailbox enabled. Email ingress vector discarded.	The login originates from an internal IP (10.50.8.45). This reduces the probability of a direct external access, but does not confirm that the authentication was legitimate. We cannot confirm their physical location or if they are using the endpoint via RDP from historical data. CHG-2026-1842: "Quarterly password rotation." Evidence insufficient to confirm a successful brute force attack. Signal: This signal is emitted as the first alert of the session.	MEDIUM	MEDIUM	-
TKT-04156	There is a data transfer from srv-backup-01 to an external IP with no historical record: 203.0.113.45. Transfer lasted 30 minutes, volume 50GB. Connection established to an unknown domain from srv-backup-01 via admin_backup. Fri 22:15-22:45 -> 50.0 GB (HTTPS) Sat 03:00-03:45 -> 18.4 GB (HTTPS) Sat 07:30-07:45 -> 4.2 GB (HTTPS) Fri 22:14 cdn-us-east-19.streamcloud.io - NEW DOMAIN resolved to 203.0.113.45. The alert is valid due to Data Exfiltration	Signal: Mention of a technician using credentials from an unknown IP to perform a backup might be plausible given the date. However, we observed that powershell.exe established the outbound connection to 203.0.113.45, temporarily coinciding with the start of the massive data transfer. Additional Signal: At 22:12, powershell.exe -EncodedCommand was executed with parent process rsync.exe, highly unusual for a backup process. Time discrepancies may be due to a firewall timezone configuration error.	HIGH	CRITICAL	-

ALERT ID	HYPOTHESIS	SIGNAL VS. NOISE?	SIEM SEV	OPS SEV	COP
	prevention: 22:15:08 CONN_OUT srv-backup-01:51234 -> 203.0.113.45:443 ESTABLISHED 22:16:42 DATA_OUT srv-backup-01 -> 203.0.113.45 vol 2.3GB 22:21:15 DATA_OUT vol 8.7GB 22:34:22 vol 18.4GB 22:42:18 vol 20.6GB.				
TKT-04203	Confirmed: A new firewall change was generated on srv-backup-01, allowing access to any device connecting via port 443. Access was performed via internal IP 10.50.8.0/24 to generate these changes. The user has administrative privileges. 02:30:15 FW RULE ADD by admin_backup src=srv-backup-01 dst any: 443 action allow 02:30:18 FW CONFIG_SAVE by admin_backup 02:30:22 FW RELOAD success Two minutes prior to the change, powershell.exe -EncodedCommand was executed, initiated by scheduled_task_runner.exe.	Noise that raises an alert: Historical login records exist for this server at these hours with this user. No change ticket existed for today, but it generated an unauthorized persistence mechanism via port 443. The execution of PowerShell via a scheduled task (scheduled_task_runner.exe) coincides with the firewall modification. No scheduled maintenance window for the weekend. Last calendar update: 2 weeks ago (not regularly updated). Confirm with team leads regarding off-system administrative activity.	CRITIC AL	CRITIC AL	-
TKT-04287	CONFIRMED: The account admin_backup added a member to the Domain Admins group; the change replicated successfully across Domain Controllers. The modification was preceded by powershell.exe executing: net.exe localgroup "Domain Admins" admin_backup /ADD, reinforcing correlation. 06:00:42 AD GROUP MODIFY user admin_backup group=Domain_Admis action=ADD executed_by=admin_backup source_host=srv-backup-01 06:00:45 AD_REPLICATION_START dc01->dc02 06:01:12 AD REPLICATION_COMPLETE	Signal: The admin_backup account is not authorized to modify privileged groups in this manner, although it has local admin rights to perform it. High probability of privilege abuse or a malicious actor creating persistence. The execution of net.exe immediately preceded the Active Directory log.	LOW	CRITIC AL	-

GENERAL OBSERVATIONS

- **Event TKT-04102 does not confirm a brute force attack:** The 15 failed attempts caused the account lockout, but a subsequent LOGIN_SUCCESS from an internal IP (10.50.8.45) was observed. The recent password rotation

(CHG-2026-1842) suggests the owner might have used an outdated password. However, this login kicks off the malicious event chain.

- **Strong correlation between all subsequent events:** All subsequent alerts involve the admin_backup user account on the same server (srv-backup-01). The temporal sequence is strictly consistent: Login → Backup Config Access → Resource Reconnaissance → Firewall Rule Creation → Massive Data Transfer → Privilege Escalation.
- **Data exfiltration is the strongest Indicator of Compromise (IOC):** Approximately 50 GB were transferred to an unobserved external IP (203.0.113.45) resolving from a newly seen domain. There is no evidence of an authorized backup.
- **Firewall modification drastically increases risk level:** Creating a rule allowing inbound/outbound connections over port 443 during non-operational hours strongly implies persistence. No change ticket is associated.
- **Privilege escalation represents a critical action:** Modifying the Domain Admins group and replicating it across DCs is a highly critical Active Directory alteration, even if subsequent lateral movement hasn't been logged yet.
- **Email is discarded as the initial vector:** The admin_backup account has no mailbox enabled, reducing phishing likelihood to near zero.
- **SIEM and Firewall temporal inconsistency:** The SIEM logs an exfiltration concentrated within 30 minutes, whereas the Firewall shows transfers distributed over several hours. Before concluding log manipulation, it is recommended to verify NTP synchronization, time zones, logging latency, and SIEM aggregation policies.

Most Consistent Hypothesis: The incident matches a compromised credential scenario for admin_backup. These credentials were used to access the backup server, harvest sensitive active directory data, establish firewall persistence, exfiltrate data, and escalate domain privileges. Process execution logs (powershell.exe - EncodedCommand spawned by rsync.exe and scheduled_task_runner.exe) technically link all actions.

DELIVERABLE 2. SCOPE NOTE

Main Hypothesis

The first alert generates noise and proves nothing on its own. The subsequent 4 alerts provide a comprehensive analysis indicating active data exfiltration and external connection tracking a specific timeline: 14:48 Successful Login → 14:50 Backup_Config Access → 22:15 Data Exfiltration → 02:30 Firewall Modification → 06:00 Domain Admins Escalation.

Assets Involved

srv-backup-01, Active Directory, Firewall, admin_backup account.

Data at Risk

Production database snapshots, service accounts, configuration backups (including credentials_map.enc), Active Directory configuration hashes across the infrastructure.

Time Window

Friday 14:48:03 to Saturday 06:00:00+ UTC/Local.

Recommended Decision

Containment.

Justification

It is recommended to immediately contact the credential owner of admin_backup to verify identity, but the absolute priority is contain the attack by disabling the unauthorized firewall rules created at 02:30 that limited connections via port 443, thereby closing the exposed security breach.

Detected Data Conflict

Admin permissions used to establish unrecorded/unprogrammed external connections outside business hours. Timestamps show mismatch between Firewall records and SIEM aggregation.

Technical Cause

Misconfiguration, over-privileged account permissions, clock drift between servers, non-compliance with CMDB protocols, ITSM, and change management calendar scheduling.

Applied Adjustments

NTP time synchronization check across all involved assets is required, normalizing timestamps to UTC, and validating with Infrastructure if any out-of-band administrative task occurred.

Out of Scope for Today

Full host-based forensic analysis of the server and attacker attribution will not be conducted until the incident is fully contained and evidence is safely preserved. Initial compromise vector remains unconfirmed.

Data That Would Change the Decision

- Confirmation of an authorized, out-of-band maintenance window.
- Evidence that the data transfer corresponded to a legitimate backup stream.
- Explicit confirmation from the account owner that they performed all logged actions.
- Evidence of an additional compromised account or further persistence mechanisms on other systems.

DELIVERABLE 3. CORRELATED TIMELINE

TIMESTAMP	SOURCE	CERTAINTY	EVENT DESCRIPTION
Fri 14:25:11	AD Logs	CONFIRMED	The admin_backup account triggers the 15 failed login attempts threshold and is automatically locked out.
Fri 14:48:03	AD Logs	CONFIRMED	Successful login for admin_backup from internal IP 10.50.8.45 immediately following account unlock.
Fri 14:50	AD Logs	INFERRED	Access to the Backup_Config shared resource; queries backup information, including Active Directory hashes.
Fri 22:12	EDR	CONFIRMED	Execution of powershell.exe -EncodedCommand with parent process rsync.exe. Highly anomalous behavior prior to external connection.
Fri 22:14	Proxy / DNS	UNKNOWN	Domain resolution of cdn-us-east-19.streamcloud.io pointing to IP 203.0.113.45, with no historical baseline in the organization.
Fri 22:15-22:45	Firewall	CONFIRMED	Massive data transfer of approximately 50 GB from srv-backup-01 to external IP 203.0.113.45 via HTTPS (443).
Sat 02:28	EDR	CONFIRMED	scheduled_task_runner.exe spawns powershell.exe -EncodedCommand two minutes prior to firewall rule alteration, indicating automated command execution.
Sat 02:30	Firewall	CONFIRMED	Creation and implementation of a new firewall rule permitting inbound/outbound traffic on port 443, executed under the admin_backup context.
Sat 05:58	EDR	CONFIRMED	PowerShell runs net.exe localgroup "Domain Admins" admin_backup /ADD, directly preceding the modification logged in Active Directory.

TIMESTAMP	SOURCE	CERTAINTY	EVENT DESCRIPTION
Sat 06:00	AD Logs	CONFIRMED	Active Directory group modification for Domain Admins completed by admin_backup and successfully replicated to all Domain Controllers.

Time Normalization

A time discrepancy was noted between SIEM and Firewall logs regarding the duration of the data transfer. Timestamps were not manually modified; correlation was established using logical sequence tracking. It is highly recommended to inspect NTP configurations and log aggregation latencies.

Identified Visibility Gap

Friday 14:50 - Friday 22:10: During this interval, the session remained active, but logs lack sufficient granularity to reconstruct specific actions. This period represents a visibility gap preventing tracking intermediate steps before the initial PowerShell execution.

The Narrative in 4 Lines

On Friday at 14:48, the admin_backup account successfully logged in from an internal IP after triggering a logout. The account accessed the Backup_Config resource, and hours later, executed an anomalous encoded PowerShell process to exfiltrate ~50 GB to an external IP (203.0.113.45). During Saturday morning, automated scheduled tasks executed further PowerShell commands to modify firewall rules and add the account into the Domain Admins group, indicating a critical credential compromise or privilege abuse scenario.

DELIVERABLE 4. EXECUTIVE REPORT

To: Roberto Silva (SOC Manager)
From: Leonardo Romero
Subject: Incident Report: TKT-2026-04340

• CONFIRMED

- The admin_backup account initiated a session on srv-backup-01 following a logout caused by multiple failed attempts.
- Unauthorized access to Backup_Config, a 50GB data transfer to 203.0.113.45, a firewall modification, and an addition to the Domain Admins group were detected.
- powershell.exe -EncodedCommand executed actions directly tied to the external data transmission and privilege escalation chain.

• PROBABLE

- Log evidence is strongly consistent with a valid credential compromise or malicious privilege abuse of the admin_backup account.
- The malicious use of powershell.exe was deployed to automate execution commands, establish persistence, and perform post-exploitation actions.

• UNKNOWN

- The initial entry vector of compromise has not yet been determined, nor has it been confirmed if any activity was authorized by the legal account owner.
- A temporal logging discrepancy exists between SIEM and Firewall aggregation data which remains pending validation.

• IMMEDIATE ACTION REQUIRED

Temporarily isolate and contain the admin_backup account, review all current active sessions, and restrict or revoke the unauthorized firewall rules.

• ACTION TO CLOSE GAPS

Cross-examine and validate EDR, NTP synchronization, CMDB assets records, and cross-reference official change management authorization tickets with the Infrastructure department.

Appendix: Consulted Sources

- Active Directory Logs
- Perimeter Firewall Records
- Web Proxy & DNS Lookups
- Endpoint Detection and Response (EDR) Logs
- Email Gateway Logs
- ITSM Change Management System
- Configuration Management Database (CMDB)
- Corporate Calendar Schedules